

Protect the Attacker

Governance, Risk & Compliance

Auditing a Kali Linux system with Lynis and hardening it per CIS Benchmark recommendations

Robin Reinhardt

August 2026

Kali Linux System Hardening – GRC Audit Report

Auditor: Robin Reinhardt **System:** Kali GNU/Linux Rolling (2026.3), Kernel 7.0.12+kali, VMware VM **Audit Tool:** Lynis 3.1.6 **Frameworks:** CIS Debian Linux 13 Benchmark v1.0.0 (primary), NIST 800-171 **Date:** August 2026

1. Executive Summary

This project audited and hardened a Kali Linux system following the full GRC cycle: identify → analyze → remediate → map controls → document. Lynis served as the audit tool, the CIS Debian 13 Benchmark as the remediation guide, mapped to NIST 800-171.

The initial audit produced a Hardening Index of **64**, with 1 warning and 56 suggestions. Ten findings were selected and worked through: six were remediated with configuration changes, one received a targeted partial fix with the remainder accepted as risk, one was documented as accepted risk, and two were assessed as already compliant. An additional CIS control (GPG key permissions) was verified compliant as a bonus.

After remediation and a reboot, the final scan returned a Hardening Index of **67** with the suggestion count reduced from 56 to **43** — thirteen fewer. The modest three-point index rise is discussed in the conclusion: the index heavily weights Kali's deliberately-retained offensive tooling and exposed services, which were intentionally left in place, so the score understates the security improvement actually achieved.

Metric	Initial	Final	Delta
Hardening Index	64	67	+3
Warnings	1	1	0
Suggestions	56	43	-13
Tests performed	278	281	+3

```
Details:
Hardening index : 64 [##### ]
Tests performed : 278
Plugins enabled : 1
```

Initial Hardening Index

```
Details:
Hardening index : 67 [##### ]
Tests performed : 281
Plugins enabled : 1
```

Final Hardening Index

Findings remediated: default umask, password aging, login banners, GRUB bootloader password, auditd (daemon + config + rules), unused network protocols, package tooling, SSH password authentication.

Assessed as compliant: password hashing (yescrypt), grub.cfg permissions, GPG key permissions.

Accepted risks: single nameserver, remaining SSH hardening options.

2. Initial Findings

2.1 Initial Lynis Scan

```
Lynis security scan details:

Scan mode:
Normal [X] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status      [?]
- Security audit         [V]
- Vulnerability scan     [V]

Details:
Hardening index : 64 [#####          ]
Tests performed : 278
Plugins enabled : 1

Software components:
- Firewall               [V]
- Intrusion software     [X]
- Malware scanner        [X]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat
```

2.2 Mitigation Plan / Risk Register

#	Finding (Lynis)	Description	CIS Control #	NIST 800- 171	Mitigation Plan	Status
1	AUTH-9328	Missing default umask	5.4.3.3	3.1.5	umask 027 in login.defs + profile.d	Done
2	AUTH-9286	Password aging not configured	5.4.1.1–5.4.1.3	3.5.6	PASS_MAX/MIN/WARN + chage	Done
3	AUTH-9230	Password hashing algorithm	5.4.1.4	3.13.11	Assess – yescrypt already used	Compliant
4	BANN-7126/7130	Weak login banners	1.6.2–1.6.6	3.1.9	Warning text + permissions	Done
5	BOOT-5122	No GRUB password	1.4.1	3.1.1, 3.4.5	PBKDF2 password + --unrestricted	Done
6	SSH-7408	SSH not hardened	— (Lynis)	3.1.12, 3.13.8	Disable password auth; rest accepted	Partial / Accepted
7	ACCT-9628	auditd not active	6.2.1–6.2.3	3.3.1, 3.3.2	Install auditd + config + core rules	Done

#	Finding (Lynis)	Description	CIS Control #	NIST 800-171	Mitigation Plan	Status
8	PKGS-7370 / DEB-0810	Package verification / tooling missing	— (Lynis/project)	3.4.1	debsums, apt-listbugs/-changes, apt-show-versions	Done
9	NETW-3200	Unused protocols (dccp/sctp/rds/tipc)	3.2.3–3.2.6	3.4.6	Blacklist kernel modules	Done
10	NETW-2705	Only 1 responsive nameserver	— (no CIS control)	—	Document as Accepted Risk	Accepted Risk
Bonus	CIS 1.2.1.3	GPG key file permissions	1.2.1.3	3.4.1	Verify ownership/permissions	Compliant

Status values: Not Started → In Progress → Done → Compliant → Accepted Risk / Not Applicable

3. Mitigation Process & Evidence

3.1 AUTH-9328 – Weak/Missing Default umask (CIS 5.4.3.3)

- **Risk:** No default umask was configured in `/etc/login.defs`, `/etc/profile.d/` or `/etc/bash.bashrc`, so new files defaulted to umask 022 (`-rw-r--r--`), granting all local users read access to newly created files. This violates least privilege. (NIST 800-171: 3.1.5 Least Privilege)
- **Mitigation:** Configured a default umask of `027` per CIS Debian 13 Benchmark Section 5.4.3.3, across all three locations the control specifies: ran the benchmark script to comment out weaker umask values in `/etc/profile.d/*.sh`, created `/etc/profile.d/60-default_umask.sh` with `umask 027`, and appended `UMASK 027` to `/etc/login.defs`.
- **Evidence:** Verified active value in a new shell via `umask -S` → `u=rwx,g=rx,o=`, confirming new directories become `drwxr-x---` and files `-rw-r-----`. Final Lynis scan confirms `umask (/etc/login.defs) [ OK ]`.

Remediation script (from benchmark):

```
#!/usr/bin/env bash
{
  while IFS= read -r -d $'\0' l_file; do
    sed -ri '/^s*umask\s+0?(01)[0-7]|0[0-7][^7]|[^0][0-7][0-7](\s*|\s+.)$/s/^/# /' "$l_file"
  done < <(find /etc/profile.d/ -type f -name '*.sh' -print0)
}
```

Verification – config and active value:

```
(kali@kali)-[~]
$ printf '%s\n' "" "umask 027" | sudo tee -a /etc/profile.d/60-default_umask.sh
```

```
(kali㉿kali)-[~]
$ sudo grep -i "^UMASK" /etc/login.defs
UMASK 027

(kali㉿kali)-[~]
$ cat /etc/profile.d/60-default_umask.sh
umask 027
```

```
(kali㉿kali)-[~]
$ nano ~/umask-fix.sh

(kali㉿kali)-[~]
$ sudo bash ~/umask-fix.sh
```

```
(kali㉿kali)-[~]
$ umask -S
u=rwx,g=rx,o=
```

3.2 AUTH-9286 – Password Aging Not Configured (CIS 5.4.1.1 / 5.4.1.2 / 5.4.1.3)

- **Risk:** Password aging was effectively disabled: `PASS_MAX_DAYS` was 99999 (passwords never expire) and `PASS_MIN_DAYS` was 0 (no limit on change frequency). This weakens password hygiene and lets compromised credentials remain valid indefinitely. (*NIST 800-171: 3.5.6*)
- **Mitigation:** Set `PASS_MAX_DAYS 365`, `PASS_MIN_DAYS 1`, `PASS_WARN_AGE 7` in `/etc/login.defs` for future accounts per CIS Sections 5.4.1.1–5.4.1.3, and applied the same values to existing accounts with `chage` (via the benchmark's awk one-liners over `/etc/shadow`).
- **Evidence:** `grep ^PASS_ /etc/login.defs` confirms the new defaults; `chage -l kali` confirms the existing account now shows Maximum 365 / Minimum 1 / Warning 7, with password expiry moved from 2300 to Mar 24, 2027. Final Lynis scan confirms password aging minimum/maximum [**CONFIGURED**] and **Accounts without expire date [OK]**.

Before:

```
(kali㉿kali)-[~]
$ sudo chage -l kali
[sudo] password for kali:
Last password change           : Mar 24, 2026
Password expires                : Jan 06, 2300
Password inactive               : never
Account expires                 : never
Minimum number of days between password change : 0
Maximum number of days between password change : 99999
Number of days of warning before password expires : 7
```

After:

```
(kali㉿kali)-[~]
$ sudo chage -l kali
Last password change           : Mar 24, 2026
Password expires                : Mar 24, 2027
Password inactive               : never
Account expires                 : never
Minimum number of days between password change : 1
Maximum number of days between password change : 365
Number of days of warning before password expires : 7
```

```
(kali㉿kali)-[~]
$ grep -E "^PASS_(MAX|MIN|WARN)" /etc/login.defs
PASS_MAX_DAYS    365
PASS_MIN_DAYS    1
PASS_WARN_AGE    7
```

3.3 AUTH-9230 – Password Hashing Algorithm (CIS 5.4.1.4) — *Already Compliant*

- **Risk:** Weak password hashing (e.g. MD5/DOS) would allow fast offline cracking of stolen `/etc/shadow` hashes. (*NIST 800-171: 3.13.11*)
- **Assessment:** System already uses **yescrypt**, a memory-hard algorithm explicitly accepted by CIS 5.4.1.4 (SHA512 or yescrypt). `ENCRYPT_METHOD YESCRYPT` is set in `/etc/login.defs` and PAM (`common-password`) uses the matching algorithm (`pam_unix.so obscure yescrypt`), satisfying the benchmark's consistency requirement. No change required.
- **Evidence:** `grep ENCRYPT_METHOD /etc/login.defs` → YESCRYPT; PAM line confirms yescrypt; stored hash prefix `$$` in `/etc/shadow` confirms yescrypt in active use.
- **Note on residual Lynis suggestion:** The final Lynis scan still lists AUTH-9230 ("Configure password hashing rounds in `/etc/login.defs`"). This is a known tool/benchmark divergence: the `SHA_CRYPT_*_ROUNDS` directive only applies to SHA512-based hashing. yescrypt manages its cost factor internally and ignores that directive, so setting it would have no effect. The control's underlying intent — a strong, modern hashing algorithm — is fully met. Documented as compliant rather than actioned.

CIS Recommendation:

Remediation:

Edit `/etc/login.defs` and set the `ENCRYPT_METHOD` to `SHA512` or `YESCRYPT`:

```
ENCRYPT_METHOD <HASHING_ALGORITHM>
```

Example:

```
ENCRYPT_METHOD YESCRYPT
```

Note:

- This only effects local groups' passwords created after updating the file to use `sha512` or `yescrypt`.
- If it is determined that the password algorithm being used is not `sha512` or `yescrypt`, once it is changed, it is recommended that all group passwords be updated to use the stronger hashing algorithm.
- It is recommended that the chosen hashing algorithm is consistent across `/etc/login.defs` and the PAM configuration

Evidence – already compliant:

```
(kali㉿kali)-[~]
$ sudo grep -Ei "^ENCRYPT_METHOD" /etc/login.defs
ENCRYPT_METHOD YESCRYPT

(kali㉿kali)-[~]
$ sudo grep -E "pam_unix.so" /etc/pam.d/common-password
password [success=1 default=ignore] pam_unix.so obscure yescrypt

(kali㉿kali)-[~]
$ sudo grep "^kali:" /etc/shadow | cut -d: -f2 | cut -c1-3
$$
```

3.4 BANN-7126 / BANN-7130 – Legal Login Banners (CIS 1.6.2–1.6.6)

- **Risk:** `/etc/issue` and `/etc/issue.net` contained the default OS/version string with escape placeholders (`\n`, `\l`) instead of a legal warning. This disclosed OS information pre-authentication and provided no notice that access is restricted, weakening the legal basis for pursuing unauthorized access. (*NIST 800-171: 3.1.9 System Use Notification*)
- **Mitigation:** Replaced the contents of `/etc/issue` and `/etc/issue.net` with a neutral authorized-use warning per CIS 1.6.2/1.6.3, removing all OS references and placeholders. Set ownership `root:root` and mode `rw-r--r--` on `/etc/issue`, `/etc/issue.net` and `/etc/motd` per CIS 1.6.4–1.6.6.
- **Evidence:** `cat` before/after shows the OS string (`Kali GNU/Linux Rolling \n \l`) replaced by the warning banner; `ls -l` confirms `-rw-r--r-- root root` on all three files.
- **Note on residual Lynis suggestion:** BANN-7126/7130 still appear in the final scan. Lynis applies its own heuristic for what counts as a valid banner and does not clear these tests merely because a warning string is present; the CIS controls (1.6.2–1.6.6), which govern content and permissions, are satisfied. The divergence is a tool-specific check, not an unremediated control.

Before:

```
(kali㉿kali)-[~]  
$ cat /etc/issue  
Kali GNU/Linux Rolling \n \l  
  
(kali㉿kali)-[~]  
$ cat /etc/issue.net  
Kali GNU/Linux Rolling
```

After:

```
(kali㉿kali)-[~]  
$ cat /etc/issue  
Authorized users only. All activity may be monitored and reported.  
  
(kali㉿kali)-[~]  
$ cat /etc/issue.net  
Authorized users only. All activity may be monitored and reported.  
  
(kali㉿kali)-[~]  
$ ls -l /etc/issue /etc/issue.net /etc/motd  
-rw-r--r-- 1 root root 67 Aug 16 22:17 /etc/issue  
-rw-r--r-- 1 root root 67 Aug 16 22:18 /etc/issue.net  
-rw-r--r-- 1 root root 282 Nov 10 2025 /etc/motd
```


3.5 BOOT-5122 – GRUB Bootloader Password (CIS 1.4.1)

- **Risk:** Without a bootloader password, anyone with console/physical access can edit GRUB entries at boot (e.g. append `init=/bin/bash`) to gain unauthenticated root access. (NIST 800-171: 3.1.1, 3.4.5; NIST 800-53 AC-3)
- **Mitigation:** Generated a PBKDF2 hash (`grub-mkpasswd-pbkdf2`, 600 000 iterations), set `superusers` + `password_pbkdf2` in `/etc/grub.d/40_custom` per CIS 1.4.1, and added `--unrestricted` to `/etc/grub.d/10_linux` so the system boots without a prompt while GRUB edit/console access requires authentication. Ran `update-grub` and rebooted.
- **Evidence:** `grep` on generated `/boot/grub/grub.cfg` confirms `set superusers`, `password_pbkdf2`, and `--unrestricted` on all menuentries; system rebooted normally (verified via SSH reconnect). Final Lynis scan confirms `Checking for password protection [ OK ]` (was `[ NONE ]`).
- **Note:** `/etc/grub.d/10_linux` may be overwritten by `grub-common` package updates (per CIS additional info); re-check after GRUB updates. `/boot/grub/grub.cfg` permissions already compliant (600, root:root) per CIS 1.4.2.

Before (no bootloader password set):

```
(kali㉿kali)-[~]
$ sudo grep -E "password|superusers" /etc/grub.d/* 2>/dev/null

(kali㉿kali)-[~]
$ ls -l /boot/grub/grub.cfg
-rw----- 1 root root 12877 Aug 14 22:11 /boot/grub/grub.cfg
```

Config – `--unrestricted` in `10_linux`:

```
(kali㉿kali)-[~]
$ sudo cp /etc/grub.d/10_linux /etc/grub.d/10_linux.bak

(kali㉿kali)-[~]
$ sudo grep "CLASS=" /etc/grub.d/10_linux
CLASS="--class gnu-linux --class gnu --class os"
CLASS="--class $(echo ${GRUB_DISTRIBUTOR} | tr 'A-Z' 'a-z' | cut -d' ' -f1|LC_ALL=C sed 's,[^:alnum:_,],,g') ${CLASS}"
```

After – generated `grub.cfg` contains `superusers` / `password_pbkdf2` / `--unrestricted`:

```
(kali㉿kali)-[~]
$ sudo grep -E "superusers|password_pbkdf2|unrestricted" /boot/grub/grub.cfg
menuentry 'Kali GNU/Linux' --class kali --class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-simple-484261e5-116f-46e4-95c7-9c438f49d3b0' {
  menuentry 'Kali GNU/Linux, with Linux 7.0.12+kali-amd64' --class kali --class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-7.0.12+kali-amd64-advanced-484261e5-116f-46e4-95c7-9c438f49d3b0' {
  menuentry 'Kali GNU/Linux, with Linux 7.0.12+kali-amd64 (recovery mode)' --class kali --class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-7.0.12+kali-amd64-recovery-484261e5-116f-46e4-95c7-9c438f49d3b0' {
  menuentry 'Kali GNU/Linux, with Linux 6.19.14+kali-amd64' --class kali --class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-6.19.14+kali-amd64-advanced-484261e5-116f-46e4-95c7-9c438f49d3b0' {
  menuentry 'Kali GNU/Linux, with Linux 6.19.14+kali-amd64 (recovery mode)' --class kali --class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-6.19.14+kali-amd64-recovery-484261e5-116f-46e4-95c7-9c438f49d3b0' {
  menuentry 'Kali GNU/Linux, with Linux 6.18.12+kali-amd64' --class kali --class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-6.18.12+kali-amd64-advanced-484261e5-116f-46e4-95c7-9c438f49d3b0' {
  menuentry 'Kali GNU/Linux, with Linux 6.18.12+kali-amd64 (recovery mode)' --class kali --class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-6.18.12+kali-amd64-recovery-484261e5-116f-46e4-95c7-9c438f49d3b0' {
  menuentry 'Kali GNU/Linux, with Linux 6.16.8+kali-amd64' --class kali --class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-6.16.8+kali-amd64-advanced-484261e5-116f-46e4-95c7-9c438f49d3b0' {
  menuentry 'Kali GNU/Linux, with Linux 6.16.8+kali-amd64 (recovery mode)' --class kali --class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-6.16.8+kali-amd64-recovery-484261e5-116f-46e4-95c7-9c438f49d3b0' {
set superusers="kali"
password_pbkdf2 kali grub.pbkdf2.sha512.600000.
2EE514980DE29EBC88C842E7CF6B6B731326A184F
```

```
set superusers="kali"
password_pbkdf2 kali grub.pbkdf2.sha512.600000.
2EE514980DE29EBC88C842E7CF6B6B731326A184F
```

```
os --unrestricted $menuentry_id_option 'gnulinux-simple-484261e5-116f-46e4-95c7-9c438f49d3b0' {
--class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-7.0.12+kali-amd64-advanced-484261e5-116f-46e4-95c7-9c438f49d3b0' {
)' --class kali --class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-7.0.12+kali-amd64-recovery-484261e5-116f-46e4-95c7-9c438f49d3b0' {
--class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-6.19.14+kali-amd64-advanced-484261e5-116f-46e4-95c7-9c438f49d3b0' {
e)' --class kali --class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-6.19.14+kali-amd64-recovery-484261e5-116f-46e4-95c7-9c438f49d3b0' {
--class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-6.18.12+kali-amd64-advanced-484261e5-116f-46e4-95c7-9c438f49d3b0' {
e)' --class kali --class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-6.18.12+kali-amd64-recovery-484261e5-116f-46e4-95c7-9c438f49d3b0' {
--class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-6.16.8+kali-amd64-advanced-484261e5-116f-46e4-95c7-9c438f49d3b0' {
)' --class kali --class gnu-linux --class gnu --class os --unrestricted $menuentry_id_option 'gnulinux-6.16.8+kali-amd64-recovery-484261e5-116f-46e4-95c7-9c438f49d3b0' {
```


3.6 ACCT-9628 – Audit Daemon, Configuration & Rules (CIS 6.2.1 / 6.2.2 / 6.2.3)

- **Risk:** Without **auditd**, security-relevant events (authentication, privilege use, changes to identity and configuration files) are not recorded, leaving no forensic trail for detection or incident response. (*NIST 800-171: 3.3.1, 3.3.2 Audit & Accountability*)
- **Mitigation:**
 - **6.2.1** Installed **auditd** + **auditd-plugins**; unmasked, enabled and started the service.
 - **6.2.2** Set **max_log_file_action = keep_logs** (CIS 6.2.2.2) to prevent automatic deletion of audit logs. **max_log_file = 8** already compliant (6.2.2.1).
 - **6.2.3** Deployed a curated core rule set in **/etc/audit/rules.d/cis-core.rules** (13 rules) covering identity files (**passwd/shadow/group/gshadow**), sudoers scope, login records, audit-config self-protection, sudo/privilege use, and system identity — loaded via **augenrules**.
- **Accepted Risks (documented deviations):**
 - **6.2.2.3** **admin_space_left_action** kept at **SUSPEND** rather than CIS **single/halt**; halting the VM on a full audit log is disproportionate in a lab, and **keep_logs** + bounded **max_log_file** already control growth.
 - **6.2.2.4** **space_left_action = SYSLOG** retained instead of CIS **email/exec/single/halt**; **email** requires a configured MTA not present in the lab, and syslog fulfils the low-space-notification intent.
 - **6.2.3 (scope)** A curated core rule set was chosen over the full CIS rule catalogue; heavy syscall rules (e.g. **execve**, **chmod/chown** tracking) were omitted to avoid excessive log volume on an actively used offensive system.
- **Evidence:** **dpkg -l + systemctl is-active/is-enabled** (auditd active/enabled); **auditctl -s** (**enabled 1**, pid running); **auditctl -l** lists the 13 loaded rules; **live verification** — **touch /etc/hosts** followed by **ausearch -k system-locale** produced a SYSCALL record with **key="system-locale"**, **exe="/usr/bin/touch"**, **aid=1000**, confirming the rule actively logs and attributes the action to the originating user.

Before (auditd not installed):

```
(kali㉿kali)-[~]
$ dpkg -l | grep -E "^ii\s+auditd"

(kali㉿kali)-[~]
$ systemctl status auditd 2>/dev/null | head -5
```

After – installed, active, enabled:

```

(kali㉿kali)-[~]
└─$ dpkg -l | grep -E "auditd|audispd"
ii  audispd-plugins      1:4.1.2-1+b1      amd64      Plugins for the audit event dispatcher
ii  auditd               1:4.1.2-1+b1      amd64      User space tools for security auditing
ii  libauplugin1:amd64   1:4.1.2-1+b1      amd64      Dynamic library for auditd plugins

(kali㉿kali)-[~]
└─$ systemctl is-active auditd
active

(kali㉿kali)-[~]
└─$ systemctl is-enabled auditd
enabled

(kali㉿kali)-[~]
└─$ sudo auditctl -s
enabled 1
failure 1
pid 83915
rate_limit 0
backlog_limit 8192
lost 0
backlog 0
backlog_wait_time 60000
backlog_wait_time_actual 0
loginuid_immutable 0 unlocked

```

Config (6.2.2) before / after:

```

(kali㉿kali)-[~]
└─$ sudo grep -E "max_log_file|max_log_file_action|space_left_action|admin_space_left_action" /etc/audit/auditd.conf
max_log_file = 8
max_log_file_action = ROTATE
space_left_action = SYSLOG
admin_space_left_action = SUSPEND

```

```

(kali㉿kali)-[~]
└─$ sudo grep -E "max_log_file|max_log_file_action|space_left_action|admin_space_left_action" /etc/audit/auditd.conf
max_log_file = 8
max_log_file_action = keep_logs
space_left_action = SYSLOG
admin_space_left_action = SUSPEND

```

Rules (6.2.3) – core rule set and loaded rules:

```

(kali㉿kali)-[~]
└─$ sudo cat /etc/audit/rules.d/cis-core.rules
## Identity / account changes (CIS 6.2.3.x)
-w /etc/passwd -p wa -k identity
-w /etc/shadow -p wa -k identity
-w /etc/group -p wa -k identity
-w /etc/gshadow -p wa -k identity

## Sudoers changes
-w /etc/sudoers -p wa -k scope
-w /etc/sudoers.d/ -p wa -k scope

## Login / logout events
-w /var/log/lastlog -p wa -k logins
-w /var/log/faillog -p wa -k logins

## Changes to audit config itself
-w /etc/audit/ -p wa -k auditconfig
-w /etc/audit/rules.d/ -p wa -k auditconfig

## Sudo log / privilege escalation
-w /var/log/sudo.log -p wa -k actions

## System locale / network identity
-w /etc/hostname -p wa -k system-locale
-w /etc/hosts -p wa -k system-locale

```

```
(kali㉿kali)-[~]
$ sudo auditctl -l
-w /etc/passwd -p wa -k identity
-w /etc/shadow -p wa -k identity
-w /etc/group -p wa -k identity
-w /etc/gshadow -p wa -k identity
-w /etc/sudoers -p wa -k scope
-w /etc/sudoers.d -p wa -k scope
-w /var/log/lastlog -p wa -k logins
-w /var/log/faillog -p wa -k logins
-w /etc/audit -p wa -k auditconfig
-w /etc/audit/rules.d -p wa -k auditconfig
-w /var/log/sudo.log -p wa -k actions
-w /etc/hostname -p wa -k system-locale
-w /etc/hosts -p wa -k system-locale
```

Live verification – rule fires on file access:

```
time→Mon Aug 17 17:47:16 2026
type=PROCTITLE msg=audit(1786981636.022:134): proctitle=746F756368002F6574632F686F737473
type=PATH msg=audit(1786981636.022:134): item=0 name="/etc/hosts" inode=5374215 dev=08:01 mode=0100644 ouid=0 ogid=0 rdev=00:00 nametype=NORMAL cap_f
p=0 cap_fi=0 cap_fe=0 cap_fver=0 cap_frootid=0
type=CWD msg=audit(1786981636.022:134): cwd="/home/kali"
type=SYSCALL msg=audit(1786981636.022:134): arch=c000003e syscall=257 success=yes exit=3 a0=ffffffffffff9c a1=7ffe627146bf a2=941 a3=1b6 items=1 pp
id=84206 pid=84207 auid=1000 uid=0 gid=0 euid=0 suid=0 fsuid=0 egid=0 sgid=0 fsgid=0 tty=pts1 ses=2 comm="touch" exe="/usr/bin/touch" subj=unconfined
key="system-locale"
```

3.7 PKGS-7370 / PKGS-7394 / DEB-0810 / DEB-0811 – Package Verification & Patch Tooling

- **Risk:** Without package-integrity verification (debsums), version/patch visibility (apt-show-versions) and pre-upgrade bug/change notices (apt-listbugs/apt-listchanges), tampering or regressions may go unnoticed. (*NIST 800-171: 3.4.1 Baseline configuration, 3.14.1*)
- **Assessment / Mitigation:** These four tools are recommended by Lynis and required by the project brief, but have **no direct CIS Debian 13 control** — CIS addresses package trust via GPG key signing/permissions (1.2.1.x) rather than post-install checksum verification. Installed all four; ran **debsums -s** and **apt-show-versions** to confirm they function.
- **Evidence:** **dpkg -l** before (absent) / after (all four **ii**). **debsums -s** returned five deviations, all assessed as benign: NordVPN runtime data files (updated by the app), a doc changelog, and the intentionally-decompressed **rockyou.txt.gz** wordlist — no unexpected binary tampering. **apt-show-versions** shows all packages **uptodate**. Final Lynis scan confirms **apt-listbugs/apt-listchanges [Installed]** and **debsums utility [FOUND]**.
- **Note:** Lynis PKGS-7370 now suggests enabling a debsums cron job (**CRON_CHECK**) — a follow-up hardening step beyond installing the tool.

Before / After (packages absent → installed):

```
(kali㉿kali)-[~]
$ dpkg -l | grep -E "debsums|apt-listbugs|apt-listchanges|apt-show-versions"

(kali㉿kali)-[~]
$
```

```
(kali㉿kali)-[~]
$ dpkg -l | grep -E "debsums|apt-listbugs|apt-listchanges|apt-show-versions"
ii apt-listbugs      0.1.48      all      tool which lists critical bugs before each APT installation
ii apt-listchanges  4.8+nmv3    all      package change history notification tool
ii apt-show-versions 0.22.16     all      lists available package versions with distribution
ii debsums          3.0.2.4     all      tool for verification of installed package files against MD5 checksums
```

Tools applied:

```
(kali㉿kali)-[~]
$ sudo debsums -s

debsums: changed file /usr/share/doc/libwinpr3-3/changelog.Debian.gz (from libwinpr3-3:amd64 package)
debsums: changed file /var/lib/nordvpn/data/countries.dat (from nordvpn package)
debsums: changed file /var/lib/nordvpn/data/insights.dat (from nordvpn package)
debsums: changed file /var/lib/nordvpn/data/servers.dat (from nordvpn package)
debsums: missing file /usr/share/wordlists/rockyou.txt.gz (from wordlists package)
```

```
(kali㉿kali)-[~]
$ apt-show-versions | head -20
7zip:amd64/kali-rolling 26.02+dfsg-2 uptodate
accountsservice:amd64/kali-rolling 23.13.9-8+b2 uptodate
acl:amd64/kali-rolling 2.4.0-1 uptodate
adduser:all/kali-rolling 3.158 uptodate
adwaita-icon-theme:all/kali-rolling 50.0-2 uptodate
aircrack-ng:amd64/kali-rolling 1:1.7+git20230807.4bf83f1a-3 uptodate
alsa-topology-conf:all/kali-rolling 1.2.5.1-3 uptodate
alsa-ucm-conf:all/kali-rolling 1.2.16.1-1 uptodate
amass:amd64/kali-rolling 5.1.1-0kali3 uptodate
amd64-microcode:amd64/kali-rolling 3.20251202.1 uptodate
apache2:amd64/kali-rolling 2.4.68-1 uptodate
apache2-bin:amd64/kali-rolling 2.4.68-1 uptodate
apache2-data:all/kali-rolling 2.4.68-1 uptodate
apache2-utils:amd64/kali-rolling 2.4.68-1 uptodate
apparmor:amd64/kali-rolling 4.1.7-5 uptodate
apt:amd64/kali-rolling 3.3.2+kali1 uptodate
apt-file:all/kali-rolling 3.3 uptodate
apt-listbugs:all/kali-rolling 0.1.48 uptodate
apt-listchanges:all/kali-rolling 4.8+nmuv3 uptodate
apt-show-versions:all/kali-rolling 0.22.16 uptodate
```

3.8 CIS 1.2.1.3 – GPG Key File Permissions — *Already Compliant (bonus control)*

- **Risk:** World- or group-writable APT GPG keyrings could be replaced, letting an attacker sign malicious packages as trusted. (*NIST 800-171: 3.4.1*)
- **Assessment:** All APT keyring files in `/etc/apt/trusted.gpg.d/` and `/usr/share/keyrings/` are owned `root:root` with `rw-r--r--`. The `rw-rw-rw-` entries are symlinks (permissions not applicable; their targets are correctly restricted). No change required per CIS 1.2.1.3.
- **Evidence:** `ls -l` of both directories; `find ... ! -user root -o ! -group root -o -perm /022` returns empty, confirming no non-compliant regular files.

Evidence:

```
(kali㉿kali)-[~]
$ find /etc/apt/trusted.gpg.d/ /usr/share/keyrings/ -type f \( ! -user root -o ! -group root -o -perm /022 \) 2>/dev/null
```

3.9 NETW-3200 – Unused Network Protocols (CIS 3.2.3–3.2.6)

- **Risk:** Uncommon protocols `dccp`, `sctp`, `rds` and `tipc` increase the kernel attack surface if loadable but unused; several have had past kernel CVEs. (*NIST 800-171: 3.4.6 Least Functionality*)
- **Mitigation:** For each module, unloaded it and created a `.conf` file in `/etc/modprobe.d/` with `install <mod> /bin/false` and `blacklist <mod>`, per CIS 3.2.3–3.2.6.
- **Evidence:** `/etc/modprobe.d/60-{dccp,rds,sctp,tipc}.conf` contain the two directives each. `dccp` is not present in this kernel (`modprobe: FATAL: Module dccp not found`); `rds/sctp/tipc` exist but a real load attempt is blocked — `sudo modprobe rds` returns `Error running install command '/bin/false' ... retcode 1` and `lsmod` remains empty. Final Lynis scan confirms

Uncommon network protocols [NOT FOUND] (previously listed) and NETW-3200 no longer appears in the suggestions.

- **Lesson learned:** `modprobe -n -v <mod>` is not a reliable test for `install` overrides — it prints the theoretical load path, not the `install` hook. A real `modprobe <mod>` checking the exit code plus `lsmod` is the authoritative verification.

Before (not loaded, no blacklist):

```
(kali㉿kali)-[~]
$ lsmod | grep -E "dccp|sctp|rds|tipc"

(kali㉿kali)-[~]
$ grep -rE "dccp|sctp|rds|tipc" /etc/modprobe.d/ 2>/dev/null
```

After – config files and blocked load attempts:

```
(kali㉿kali)-[~]
$ sudo cat /etc/modprobe.d/60-dccp.conf /etc/modprobe.d/60-rds.conf /etc/modprobe.d/60-sctp.conf /etc/modprobe.d/60-tipc.conf
install dccp /bin/false
blacklist dccp
install rds /bin/false
blacklist rds
install sctp /bin/false
blacklist sctp
install tipc /bin/false
blacklist tipc

(kali㉿kali)-[~]
$ lsmod | grep -E "dccp|sctp|rds|tipc"

(kali㉿kali)-[~]
$ modprobe -n -v dccp
modprobe: FATAL: Module dccp not found in directory /lib/modules/7.0.12+kali-amd64
```

```
(kali㉿kali)-[~]
$ for mod in sctp tipc; do echo "= $mod ="; sudo modprobe "$mod"; echo "exit: $?"; done
lsmod | grep -E "sctp|tipc"
= sctp =
modprobe: ERROR: Error running install command '/bin/false' for module sctp: retcode 1
modprobe: ERROR: could not insert 'sctp': Invalid argument
exit: 1
= tipc =
modprobe: ERROR: Error running install command '/bin/false' for module tipc: retcode 1
modprobe: ERROR: could not insert 'tipc': Invalid argument
exit: 1
```

```
(kali㉿kali)-[~]
$ sudo modprobe rds; echo "exit: $?"
modprobe: ERROR: Error running install command '/bin/false' for module rds: retcode 1
modprobe: ERROR: could not insert 'rds': Invalid argument
exit: 1
```

3.10 SSH-7408 – SSH Hardening (Partial Fix + Accepted Risk)

- **Risk:** Default `sshd` settings leave a wider attack surface than necessary. Most critically, `PasswordAuthentication` defaulted to `yes`, leaving the SSH service open to password brute-force attacks even though key-based login is in use. (*NIST 800-171: 3.1.12, 3.13.8*)
- **Fixed:** Set `PasswordAuthentication no` via a drop-in in `/etc/ssh/sshd_config.d/`, closing the password brute-force vector while key-based auth remains active. Verified with `sshd -T` → `passwordauthentication no, pubkeyauthentication yes`; connectivity re-tested with a second SSH session before closing the first.

- **Accepted Risk:** The remaining Lynis suggestions (custom `Port`, `MaxAuthTries`, `MaxSessions`, `X11Forwarding`, `AllowTcpForwarding`, `ClientAliveCountMax`, `LogLevel VERBOSE`, `TCPKeepAlive`, `AllowAgentForwarding`) were assessed as disproportionate for an isolated lab VM where key-only authentication already closes the primary vector. They remain in the final scan by design and are accepted rather than remediated.

Before (`sshd -T` — password auth enabled):

```
(kali㉿kali)-[~]
└─$ sudo sshd -T | grep -E "^passwordauthentication|^pubkeyauthentication|^permitrootlogin|^kbdinteractiveauthentication"
permitrootlogin prohibit-password
pubkeyauthentication yes
passwordauthentication yes
kbdinteractiveauthentication no
```

After (`sshd -T` — password auth disabled):

```
(kali㉿kali)-[~]
└─$ sudo sshd -T | grep -E "^passwordauthentication|^pubkeyauthentication|^permitrootlogin|^kbdinteractiveauthentication"
permitrootlogin prohibit-password
pubkeyauthentication yes
passwordauthentication no
kbdinteractiveauthentication no
```

3.11 NETW-2705 – Responsive Nameservers (Accepted Risk)

- **Risk:** Only one responsive nameserver reduces DNS resolution resilience; a resolver outage would break name resolution.
- **Assessment:** This is the audit's single remaining warning. There is **no direct CIS control**; the recommendation stems from Lynis tool documentation. On an isolated lab VM with a single upstream resolver (`192.168.70.1`), a second nameserver adds no meaningful resilience. Risk accepted and documented; no change made.

4. Final Results & Conclusion

4.1 Final Lynis Scan

```
Lynis security scan details:

Scan mode:
Normal [■] Forensics [ ] Integration [ ] Pentest [ ]

Lynis modules:
- Compliance status      [?]
- Security audit         [V]
- Vulnerability scan     [V]

Details:
Hardening index : 67 [#####          ]
Tests performed : 281
Plugins enabled : 1

Software components:
- Firewall              [V]
- Intrusion software    [X]
- Malware scanner       [X]

Files:
- Test and debug information : /var/log/lynis.log
- Report data                : /var/log/lynis-report.dat
```

4.2 Comparison

	Initial	Final	Delta
Hardening Index	64	67	+3
Warnings	1	1	0
Suggestions	56	43	-13
Tests performed	278	281	+3

4.3 Confirmation of Resolved Findings

The following improvements are directly confirmed in the final Lynis output:

- **umask (/etc/login.defs)** → **OK** (was a suggestion)
- Password aging minimum / maximum → **CONFIGURED**; **Accounts without expire date** → **OK**
- **GRUB Checking for password protection** → **OK** (was NONE)
- **Uncommon network protocols** → **NOT FOUND** (NETW-3200 cleared from suggestions)
- **apt-listbugs / apt-listchanges** → **Installed**; **debsums utility** → **FOUND**

Two remediated findings (BANN-7126/7130, AUTH-9230) still appear in the final scan due to tool/benchmark divergence, explained in their respective sections: the CIS controls are satisfied, but Lynis applies its own heuristics (banner content check; SHA512-oriented hashing-rounds directive that does not apply to yescrypt).

4.4 Accepted Risks / Not Applicable

Finding	Justification
NETW-2705	Lab VM; a single nameserver is sufficient. No direct CIS control; based on Lynis tool documentation only.
SSH-7408 (partial)	Key-based authentication is active and password auth disabled, closing the primary vector. Remaining options (port change, forwarding restrictions, session limits) assessed as disproportionate in an isolated lab.
auditd 6.2.2.3 / 6.2.2.4	Availability prioritised over strict audit-continuity in a lab; email action requires an MTA not present.
auditd 6.2.3 scope	Curated core rule set instead of the full CIS catalogue to avoid excessive log volume on an actively-used offensive system.
Kali offensive services & tooling (Apache, Docker, xrdp, compilers, exposed systemd units)	Retained by design — they constitute the working environment of an offensive distribution and are out of scope for this hardening exercise.

4.5 Key Learnings & Challenges

On the modest index rise (64 → 67). The three-point increase understates the work done. Thirteen suggestions were closed and every targeted control verified, but the Hardening Index also weights a large set of intentionally-retained items — **UNSAFE**-rated systemd services (docker, cups, xrdp, nordvpn, ssh), missing filesystem partitioning, present compilers, and Apache/PHP exposure — that are inherent to Kali as an offensive platform. Hardening those would degrade the system's purpose. The index therefore measures a surface from which only the sensibly-hardenable elements were removed; the large structural items remain by design. The **–13 suggestions** figure is the more honest measure of progress.

Translating tool IDs to framework controls. Lynis test IDs (AUTH-9328, BOOT-5122, NETW-3200) are Lynis-specific and do not appear in the CIS Benchmark. Each finding required a topic-based lookup (umask, bootloader password, kernel module) to locate the corresponding CIS section — a core GRC skill: mapping a tool's output onto a recognised control framework.

Knowing when *not* to act. Several findings were correctly resolved without changes: yescrypt already satisfies CIS 5.4.1.4 (the Lynis "hashing rounds" hint targets SHA512); the GPG-keyring 777 entries were symlinks, not a vulnerability. Recognising a non-issue and documenting it is as valuable as applying a fix.

Proportional risk decisions on an offensive distro. Rather than blindly applying every control, deviations were made deliberately and documented: SSH hardening reduced to the one change that matters under key-only auth; auditd's halt-on-full avoided; the full auditd rule catalogue curated down. This proportionality — matching the control to the actual risk and environment — is the essence of GRC.

Verification technique matters. The **modprobe -n -v** dry-run misleadingly suggested the protocol blacklist had failed; a real load attempt proved it worked. Trusting the right verification method, not the convenient one, is what separates a genuine control assessment from a checkbox.